

Beyond the Demo: Building Trusted AI Agents with MCP

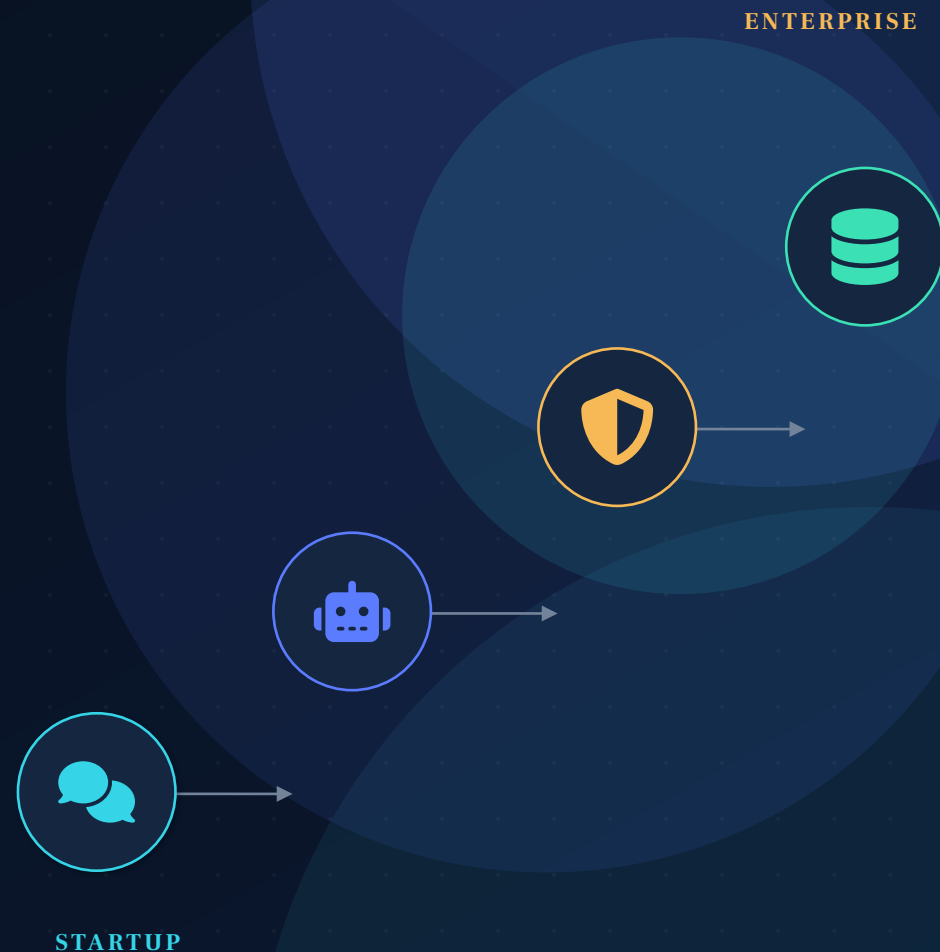
A startup story, an enterprise reality,
and lessons from a production MCP codebase.

Constantine Grigoroff

Principal Data & AI Engineer · Shell Trading & Supply

20 OCT 2026 · RAI AMSTERDAM

AI DEVELOPER · 12:05-12:35



Fictional story. Real failure modes.

You are the founding engineer.

Team of 9. Funding secured. Friday demo.

GOAL: CONNECT AN LLM TO REAL DATA THROUGH MCP

*Trusted users. One identity path. One team.
A tool catalogue small enough to understand.*

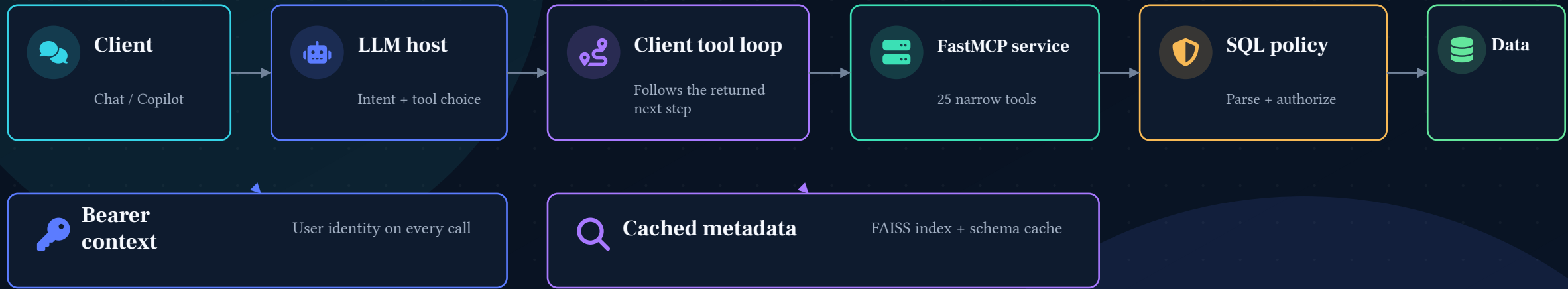


PEOPLE

ASSUMPTION DEBT

Small solutions are safe only while
their hidden assumptions remain true.

A practical MCP implementation



THE DESIGN PRINCIPLE

A deterministic spine around a probabilistic model.

The model interprets language. Code constrains execution.

OUTPUT ADAPTERS



Table



CSV



Excel



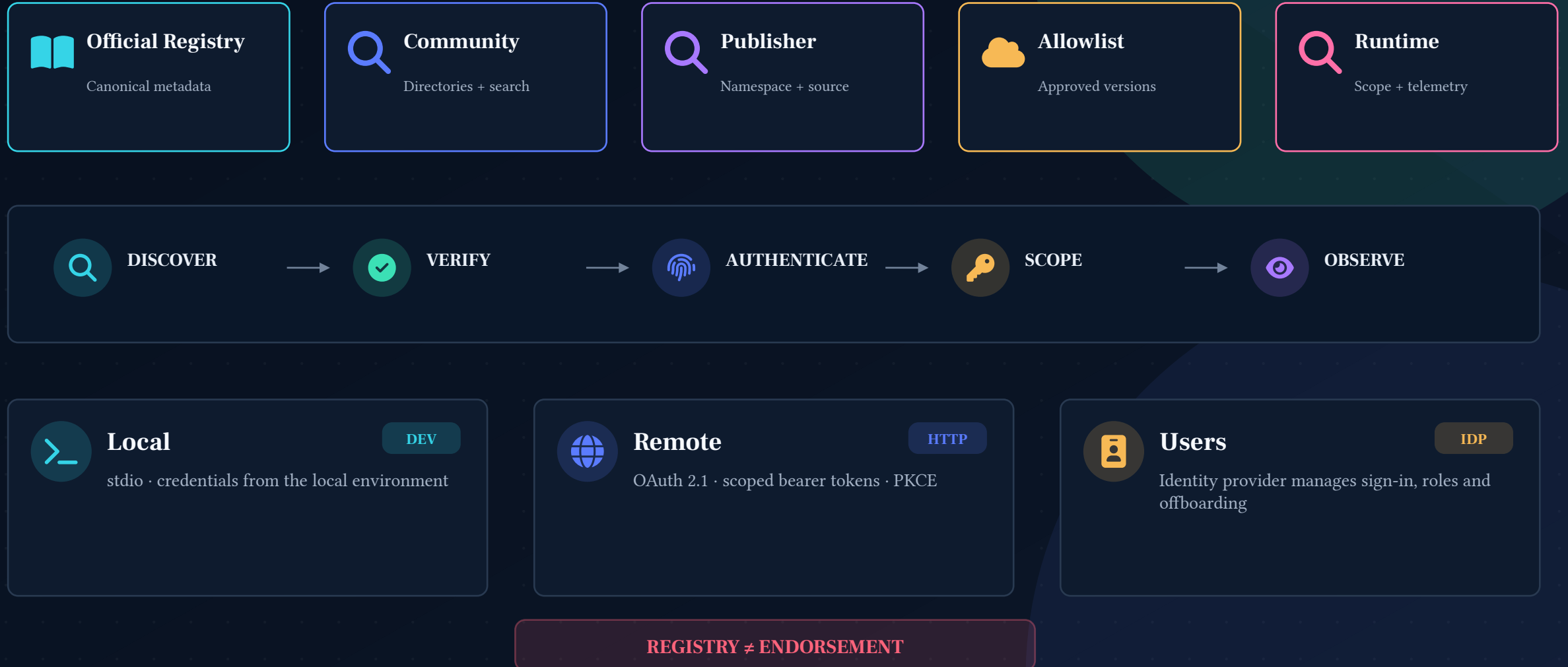
Chart



Map

STARTUP QUESTION: HOW DO WE CONTROL WHAT THE MODEL DOES?

Discovery outpaces approval



Customer acquisition: the VC arrives

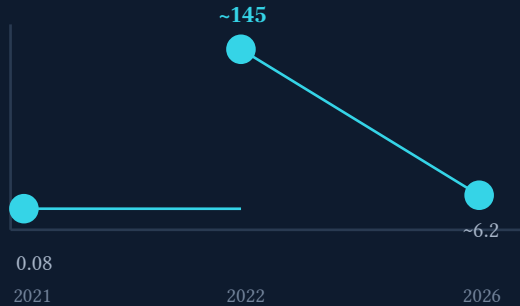
PRIORITY CUSTOMER



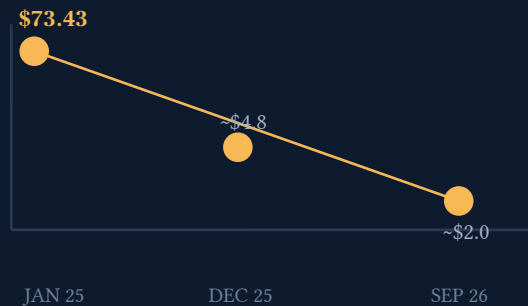
“Can your agent analyse my portfolio?”

Nothing clarifies product priorities like consequences.

BAYC FLOOR · ETH



MEME TOKEN · USD



THE REQUIREMENTS CHANGE

- 👁️ Can another user see my data?
- ⚡ Can the agent invoke a write tool?
- 🔄 Can I reproduce the answer?



Milestone illustration, not a daily price series.

Production expands the control surface



Identity & entitlements

Delegated JWT · dataset grants



Least privilege

Read-only SQL · exact relations



Guardrails

AST validation · fail closed



Audit & telemetry

Request ID · route · outcome



Evidence & provenance

Dataset · SQL · source metadata



Tests & release gates

470 passed · lint · security scans

STARTUP

Implement controls inside one product.



ENTERPRISE

Enforce controls consistently across every product.

TRUST = CONTROL + EVIDENCE

Security is not a workstream. It is the work.

50%

of surveyed MCP builders

cite security / access control
as their top challenge.



Authentication standards are
mature.
Authorization remains
contextual.



“Security and access control is the top
challenge
for builders, cited by 50% of
respondents.”

Zuplo · State of MCP survey · fielded Nov–Dec 2025 · self-selected, no N published

38%

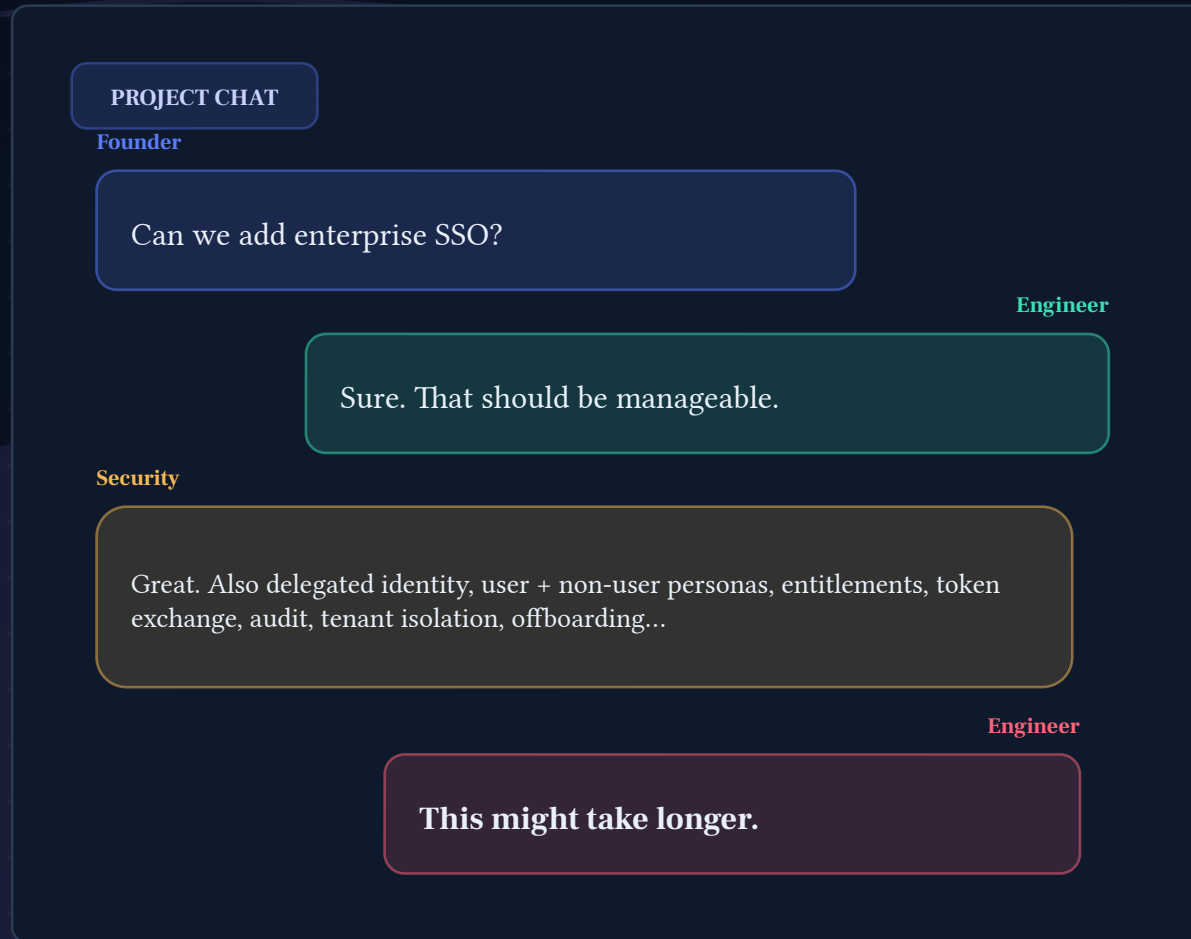
blocked by security
concerns

~24%

of respondents run
servers
with no authentication

MEASURED, NOT SELF-REPORTED: 40.55% OF 7,973 LIVE SERVERS EXPOSE TOOLS WITH NO
AUTH · [arXiv:2605.22333](https://arxiv.org/abs/2605.22333)

“This might take longer.”



Accuracy starts with routing and ends with evidence

1



Preserve the prompt

Keep the user's original wording

2



Explicit route

Return one required next step

3



Trusted template

21 fixed patterns before discovery

4



Hybrid retrieval

70% lexical · 30% vector

5



Schema + safety

Exact columns · every SQL relation

6



Execute + evidence

Authorize · read-only · request ID

CONFIDENCE GATE



LOW

HIGH



No confident
match?
Ask or stop.

SERVER

returns next step



CLIENT

calls next tool

Routing guidance is advisory; SQL safety and authorization are enforced.

REPEATABILITY COMES FROM THE ROUTE AND THE EVIDENCE

The data contract enters the routing layer



VENDOR DATA AGREEMENT

- ❌ AI processing restricted
- ❌ No model training
- ❌ Licensed users only
- ❌ No raw redistribution
- ❌ Use of derived data controlled

The policy must shape routing before the model sees the data.

Separate relevance from permission.



Terminal denial

access_denied · next_action: stop



Metadata only

Discover without raw content



Compute beside data

Return approved aggregates



Private inference

No-retention endpoints



Governed views

Approved derived products



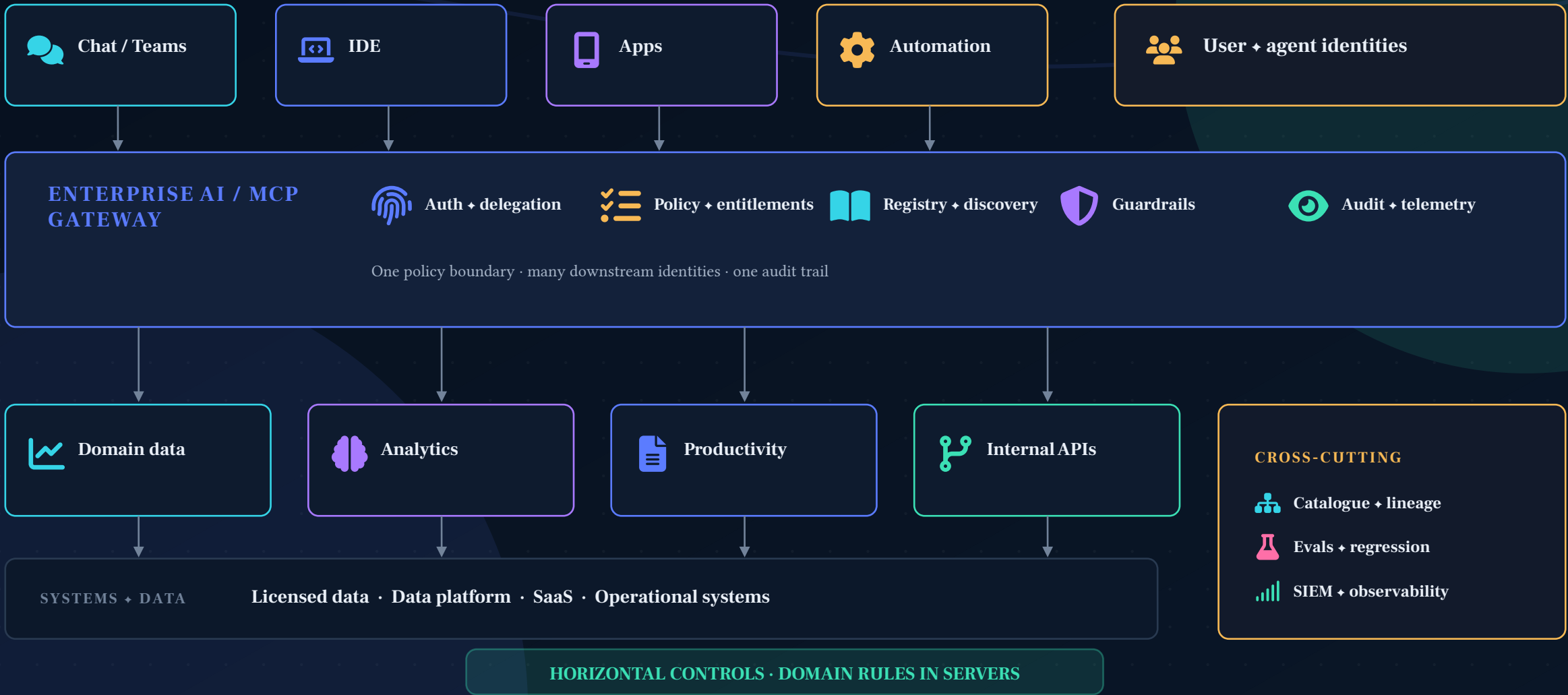
Synthetic evals

Test without licensed records

CONTRACT TERMS BECOME POLICY INPUTS

The platform around a domain MCP server

CHANNELS + PERSONAS



The dividing line

STARTUP

**Control the route
and the output.**

Client loop · routing · accuracy · UX · cost

ENTERPRISE

**Control every identity, tool and
dataset,
then retain the evidence.**

Authorization · licensing · policy · audit · operations

MAKE IT WORK

MAKE IT REPEATABLE

MAKE IT GOVERNABLE

THANK YOU



Portfolio



LinkedIn



Continue the
conversation

kolygri.github.io